

ISO/IEC 27001

SISTEMA DE GERENCIAMENTO DE SEGURANÇA DA INFORMAÇÃO

PROF. LUIS CLAUDIO, M.SC., PMP®
WWW.PROVASDETI.COM.BR

De onde Vieram estas Normas?

Código de Práticas



Especificação dos Requisitos



Como vai a Família?

ISO/IEC 27000:2014

Information security management systems

Overview and vocabulary

*This International Standard provides the **overview** of information security management systems, and **terms and definitions** commonly used in the ISMS family of standards.*

*This International Standard is applicable to **all types and sizes of organization** (e.g. commercial enterprises, government agencies, not-for-profit organizations).*

Como vai a Família?

ISO/IEC 27001:2013

Information security management systems

Requirements

*This International Standard specifies the **requirements** for **establishing, implementing, maintaining** and **continually improving** an ISMS within the context of the organization.*

*This International Standard **also** includes **requirements** for the **assessment** and **treatment** of information security risks tailored to the needs of the organization.*

*Excluding any of the requirements specified in **Clauses 4 to 10** is not acceptable when an organization claims conformity to this International Standard.*

Como vai a Família?

ISO/IEC 27002:2013

Code of practice for information security controls

This International Standard gives **guidelines** for organizational information security standards and information security management practices including the **selection, implementation and management of controls** taking into consideration the organization's information security risk environment(s).

Como vai a Família?

ISO/IEC 27003:2010

Information security management system implementation guidance

This International Standard focuses on the **critical** aspects needed for **successful** design and implementation of an ISMS in accordance with ISO/IEC 27001:2005.

It describes the process of ISMS specification and design from inception to the production of implementation plans. It describes the process of **obtaining management approval** to implement an ISMS, defines a **project** to implement an ISMS, and provides guidance on how to plan the ISMS project, resulting in a final ISMS **project implementation plan**.

Como vai a Família?

ISO/IEC 27004:2009

Information security management

Measurement

This International Standard provides guidance on the development and use of **measures** and **measurement** in order to assess the **effectiveness** of an implemented ISMS and controls or groups of controls, as specified in ISO/IEC 27001.

Como vai a Família?

ISO/IEC 27005:2011

Information security risk management

This International Standard provides guidelines for information security **risk** management.

Knowledge of the concepts, models, processes and terminologies described in **ISO/IEC 27001** and **ISO/IEC 27002** is important for a complete understanding of this International Standard.

QUESTÕES

FGV/2014 - DPE-RJ - Técnico - Segurança da Informação

Uma instituição pretende implantar um sistema de gestão da segurança da informação. Para isso, ela deve seguir as orientações da norma:

- a) ISO 27001.
- b) ISO 27002.
- c) ISO 27005.
- d) ISO 27006.
- e) ISO 27010.

QUESTÕES - Gabarito

FGV/2014 - DPE-RJ: Alternativa A

Seção 0 - Introdução

- Fornecer requisitos para **estabelecer, implementar, manter e melhorar continuamente** um SGSI.
- A adoção de um SGSI é uma **decisão estratégica** e é influenciada pelas suas necessidades e objetivos, requisitos de segurança, processos organizacionais, funcionários, tamanho e estrutura da organização.
- É esperado que todos estes fatores de influência **mudem ao longo do tempo.**

Seção 0 - Introdução

- O **SGSI** **preserva** a confidencialidade, integridade e disponibilidade da informação **por meio da aplicação de um processo de gestão de riscos** e fornece confiança para as partes interessadas de que os riscos são gerenciados.
- É importante que um **SGSI** seja parte e esteja **integrado** com os processos da organização e com a estrutura de administração **global**.

Seção 0 - Introdução

- Esta Norma pode ser usada por **partes internas e externas** para **avaliar a capacidade da organização** em atender os seus próprios requisitos de segurança da informação.
- A **ordem** pela qual os requisitos são apresentados nesta Norma não reflete sua importância ou implica uma ordem pela qual eles devem ser implementados.

Seção 1 - Escopo

- Especifica os **requisitos** para **estabelecer, implementar, manter e melhorar continuamente** um SGSI no contexto da organização.
- Esta Norma também inclui **requisitos** para a **avaliação e tratamento de riscos de segurança da informação** voltados para as necessidades da organização.
- A **exclusão** de quaisquer dos requisitos especificados nas seções 4 a 10 **NÃO é aceitável**.

Seção 2 - Referências

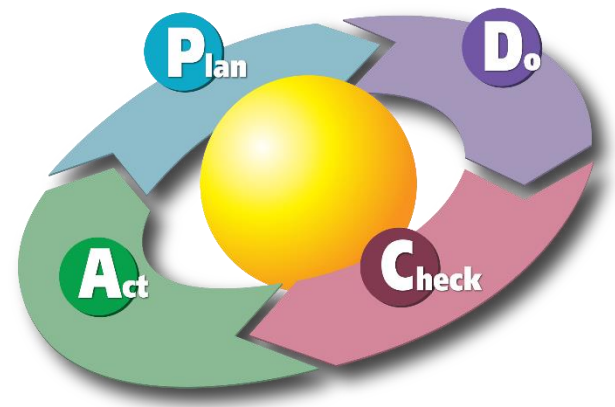
- A ISO/IEC 27000 (*Information technology -- Security techniques -- Information security management systems -- Overview and vocabulary*) é **indispensável** à aplicação deste documento.

Seção 3 - Termos e Definições

- Para os efeitos deste documento, aplicam-se os termos e definições apresentados na ISO/IEC 27000.

Seções 4 a 10 – Requisitos da Norma!

- 4 Contexto da organização
- 5 Liderança
- 6 Planejamento
- 7 Apoio (*Support*)
- 8 Operação
- 9 Avaliação do Desempenho
- 10 Melhoria



Anexo A (Controles e Objetivos de Controle)

Annex A

(normative)

Reference control objectives and controls

The control objectives and controls listed in [Table A.1](#) are directly derived from and aligned with those listed in ISO/IEC 27002:2013[1], Clauses 5 to 18 and are to be used in context with [Clause 6.1.3](#).

Table A.1 — Control objectives and controls

A.5 Information security policies		
A.5.1 Management direction for information security		
Objective: To provide management direction and support for information security in accordance with business requirements and relevant laws and regulations.		
A.5.1.1	Policies for information security	<i>Control</i> A set of policies for information security shall be defined, approved by management, published and communicated to employees and relevant external parties.
A.5.1.2	Review of the policies for information security	<i>Control</i> The policies for information security shall be reviewed at planned intervals or if significant changes occur to ensure their continuing suitability, adequacy and effectiveness.

QUESTÕES

FPM-RS/2013 - MPE-AC - Analista - Tecnologia da Informação

Qual é o objetivo da Norma NBR ISO/IEC 27001?

- a) Fornecer o vocabulário e as definições utilizadas em todas as normas da série ISO 27000 voltadas à gestão da segurança da informação visando a uniformizar a terminologia a ser empregada nas políticas de segurança a serem adotadas por uma organização.
- b) Organizar os mecanismos para estabelecer, implementar, operar, monitorar, revisar, manter e melhorar um sistema para gerência da segurança da informação (ISMS—Information Security Management System), sendo a norma usada como base para a certificação em segurança da informação.
- c) Organizar os controles de segurança da informação, reunindo as melhores práticas e servindo de base para a implantação de controle de ativos de informação, segurança de ambientes físicos e lógicos e de controles de acesso.

QUESTÕES

FPM-RS/2013 - MPE-AC - Analista - Tecnologia da Informação

Qual é o objetivo da Norma NBR ISO/IEC 27001?

- d) Estabelecer métricas para a medição da efetividade da implantação do sistema para gerência da segurança da informação (ISMS – Information Security Management System) e de seus controles.
- e) Oferecer um padrão para gerenciamento de risco, com diretrizes e orientações para identificar, avaliar, tratar e gerir os riscos sobre os recursos do escopo definido para o sistema para gerência da segurança da informação (ISMS – Information Security Management System).

QUESTÕES

MSGás/2015 - MSGás - Analista de Tecnologia da Informação

A norma que especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação dentro do contexto da organização é a:

- a) ABNT NBR ISO/IEC 27004:2010.
- b) ABNT NBR ISO/IEC 27001:2013.
- c) ABNT NBR ISO/IEC 27003:2011.
- d) ABNT NBR ISO/IEC 27002:2013.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

O escopo da Norma ISO/IEC 27001 especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente o SGSI, mas não faz parte de seu escopo definir requisitos para a avaliação e tratamento de riscos de segurança da informação.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

A exclusão de quaisquer dos requisitos especificados nas seções 1 a 10, assim como a exclusão de controles, não é aceitável quando a organização busca a conformidade com esta Norma.

QUESTÕES

IADS/2014 - UFBA - Técnico em Informática

Existem normas e padrões internacionais para melhorar a gestão da segurança da informação. Assinale a alternativa que indica a norma NBR ISO/IEC que é conhecida como o código de boas práticas em segurança da informação e que vem substituir a norma NBR ISO/IEC 17799:2005.

- a) 27001.
- b) 27003.
- c) 27002.
- d) 17800.
- e) 17801.

QUESTÕES

QUADRIX/2014 - DATAPREV - Analista Tecnologia da Informação

Quando se trata de segurança da informação, devemos sempre nos preocupar com normas e procedimentos que a empresa vai seguir para suas atividades, a fim de proteger sua informação e a de seu cliente, visam a essa segurança (embora seguir as normas não seja garantia total de segurança). Considerando essa preocupação, a ISO criou a série 27000... uma das quais trata da gestão de riscos, fornecendo diretrizes para o gerenciamento de informações de risco. Identifique, a seguir, qual alternativa contém essa norma.

- a) ISO 27004.
- b) ISO 27006.
- c) ISO 27005.
- d) ISO 27003.
- e) ISO 27002.

QUESTÕES

FGV/2013 - AL-MT - Analista de Sistemas

Com relação à Gestão da Segurança da Informação, assinale a alternativa que indica a norma especificamente destinada a fornecer orientação para o gerenciamento de risco da segurança da informação.

- a) ISO/IEC 27001
- b) ISO/IEC 27002
- c) ISO/IEC 27005
- d) ISO/IEC 27006
- e) ISO/IEC 27010

QUESTÕES

CESPE/2013 - TCE-ES - Analista Administrativo - Informática

Um sistema de gestão de segurança da informação (SGSI) fornece uma abordagem sistemática na gestão de informações confidenciais da organização para mantê-la segura e tem como referências as normas ISO/IEC 27001 e 27002. Acerca desse tema, assinale a opção correta.

- a) Todos os controles previstos em norma devem ser implementados para que a organização tenha a certeza de ter atingido o mais elevado nível de proteção.
- b) As normas NBR ISO/IEC 27001 e 27002 dizem respeito às práticas de implementação de controles e dos requisitos para a construção de um SGSI, respectivamente.

QUESTÕES

CESPE/2013 - TCE-ES - Analista Administrativo - Informática

Um sistema de gestão de segurança da informação (SGSI) fornece uma abordagem sistemática na gestão de informações confidenciais da organização para mantê-la segura e tem como referências as normas ISO/IEC 27001 e 27002. Acerca desse tema, assinale a opção correta.

- c) Risco residual é aquele que não necessita de tratamento de riscos.
- d) A implementação do SGSI garante à organização a inviolabilidade das suas informações.
- e) A ISO/IEC 27001 adota o modelo conhecido como PDCA (plan-do-check-act), que é aplicado para estruturar os processos do SGSI.

QUESTÕES

CEFET-MG/2014 - CEFET-MG - Técnico de Tecnologia da Informação

Os princípios básicos da segurança da informação, conforme definição da norma ABNT NBR ISO/IEC 27002, são

- a) disponibilidade, integridade e razoabilidade.
- b) identificabilidade, integridade e razoabilidade.
- c) confidencialidade, disponibilidade e integridade.
- d) confidencialidade, identificabilidade e razoabilidade.
- e) confidencialidade, disponibilidade e identificabilidade.

QUESTÕES - Gabarito

FPM-RS/2013 - MPE-AC: Alternativa B

MSGás/2015 - MSGás: Alternativa B

ITNERANTE/2015: FALSO

ITNERANTE/2015: FALSO

IADS/2014 - UFBA: Alternativa C

QUADRIX/2014 - DATAPREV: Alternativa C

FGV/2013 - AL-MT: Alternativa C

CESPE/2013 - TCE-ES: Alternativa E

CEFET-MG/2014 - CEFET-MG: Alternativa C

Seção 4 - Contexto da Organização

- ✅ 4.1 Entendendo a organização e seu contexto
- ✅ 4.2 Entendendo as necessidades e as expectativas das partes interessadas
- ✅ 4.3 Determinando o escopo do SGSI
- ✅ 4.4 Sistema de Gestão da Segurança da Informação

Seção 4 - Contexto da Organização

4.1 Entendendo a organização e seu contexto

A organização deve determinar as questões internas e externas que são relevantes para o seu propósito e que afetam sua capacidade para alcançar os resultados pretendidos do seu SGSI.

NOTA A determinação destas questões refere-se ao estabelecimento do contexto interno e externo da organização apresentado no item 5.3 da ABNT NBR ISO/IEC 31000 (Gestão de Riscos – Princípios e Diretrizes).

Seção 4 - Contexto da Organização

4.2 Entendendo as necessidades e as expectativas das partes interessadas

A organização deve determinar:

- a) as partes interessadas relevantes para o SGSI;
- b) os requisitos dessas partes interessadas.

NOTA Os requisitos das partes interessadas podem incluir requisitos legais e regulamentares, bem como obrigações contratuais.

Seção 4 - Contexto da Organização

4.3 Determinando o escopo do SGSI

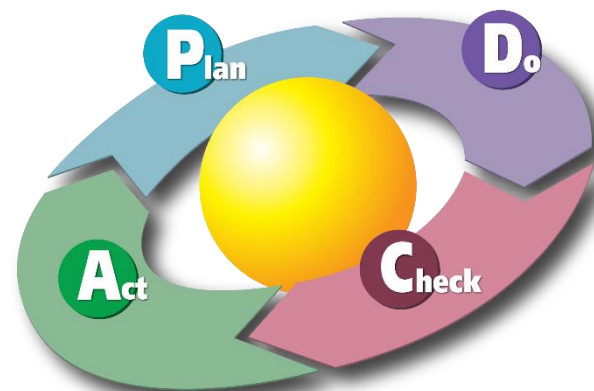
A organização deve determinar os limites e a aplicabilidade do SGSI para estabelecer o seu escopo considerando:

- a) O item 4.1;
- b) O item 4.2; e
- c) as interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por outra organização.

Seção 4 - Contexto da Organização

4.4 Sistema de Gestão da Segurança da Informação

A organização deve estabelecer, implementar, manter e melhorar continuamente um sistema de gestão da segurança da informação, **de acordo com os requisitos desta Norma.**



QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

A organização deve garantir a efetividade do SGSI fazendo o necessário para blindá-la com relação às questões externas que possam afetar sua capacidade de alcançar os objetivos de segurança da informação pretendidos pelo SGSI.

QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

O escopo de aplicação do SGSI deve considerar as questões internas e externas que sejam relevantes para o seu propósito, os requisitos das partes interessadas e as interfaces e dependências entre as atividades desempenhadas pela organização e aquelas que são desempenhadas por partes externas.

QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

Os requisitos para o SGSI de uma organização podem ser oriundos de legislações, regulamentos ou contratos firmados entre a organização e um fornecedor.

QUESTÕES - Gabarito

ITNERANTE/2015: FALSO

ITNERANTE/2015: VERDADEIRO

ITNERANTE/2015: VERDADEIRO

Seção 5 - Liderança

- ✅ 5.1 Liderança e comprometimento
- ✅ 5.2 Política
- ✅ 5.3 Autoridades, responsabilidades e papéis organizacionais

Seção 5 - Liderança

5.1 Liderança e comprometimento

A **Alta Direção** deve demonstrar comprometimento e liderança em relação ao SGSI pelos seguintes meios:

- a) assegurando que a política e os objetivos de SI estão estabelecidos e são compatíveis com a estratégia;
- b) garantindo a integração do SGSI na organização;
- c) assegurando os recursos necessários para o SGSI;
- d) comunicando a importância do SGSI;

Seção 5 - Liderança

5.1 Liderança e comprometimento

A **Alta Direção** deve demonstrar comprometimento e liderança em relação ao SGSI pelos seguintes meios:

- e) assegurando que o SGSI é efetivo;
- f) orientando e apoiando pessoas;
- g) promovendo a melhoria contínua;
- h) apoiando os papéis relevantes da gestão.

Seção 5 - Liderança

5.2 Política

A **Alta Direção** deve estabelecer uma política de SI que:

- a) seja apropriada ao propósito da organização;
- b) inclua os objetivos de SI (**ver 6.2**) OU forneça a estrutura para estabelecer os objetivos de SI;
- c) inclua um comprometimento para satisfazer os requisitos aplicáveis; e
- d) inclua um comprometimento para a melhoria contínua do SGSI.

Seção 5 - Liderança

5.2 Política

Esta política de segurança da informação deve:

- a) estar disponível como informação **documentada**;
- b) ser comunicada **dentro da organização**; e
- c) estar disponível para as **partes interessadas** conforme apropriado.

Seção 5 - Liderança

5.3 Autoridades, responsabilidades e papéis organizacionais

A **Alta Direção** deve atribuir a responsabilidade e autoridade para:

- a) assegurar que o SGSI está em conformidade com os requisitos desta Norma;
- b) relatar sobre o desempenho do SGSI para a Alta Direção.

NOTA A Alta Direção pode também atribuir responsabilidades e autoridades para relatar o desempenho do sistema de gestão da segurança da informação dentro da organização.

QUESTÕES

TIMASTERS/2015

Segundo a Norma ISO/IEC 27001 é responsabilidade da Alta Administração executar as atividades abaixo, exceto:

- a) Assegurar que a política de SI seja compatível com a estratégia.
- b) Garantir a integração do SGSI com os processos da organização.
- c) Assegurar a efetividade do SGSI.
- d) Orientar pessoas e apoiar os papéis relevantes da gestão.
- e) Relatar sobre o desempenho do SGSI dentro da organização.

QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

A norma ISO/IEC 27001, que trata do Sistema de Gerenciamento de Segurança da Informação, é eminentemente técnica. Embora ela possua requisitos que afetam toda a organização, não há, de forma explícita em seu texto, considerações sobre atividades a serem diretamente executadas pela Alta Direção.

QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

Um dos requisitos da norma ISO/IEC 27001 é o de que a Alta Direção deve estabelecer uma política de segurança da informação e nela determinar os objetivos de segurança da informação.

QUESTÕES

ITNERANTE/2015

Julgue os itens abaixo segundo a Norma ISO/IEC 27001:

A norma ISO/IEC 27001 tem como requisito que a organização retenha informação documentada, impressa e assinada sobre os objetivos de segurança da informação e sobre o processo de avaliação e tratamento dos riscos.

QUESTÕES - Gabarito

TIMASTERS/2015: Alternativa E

ITNERANTE/2015: FALSO

ITNERANTE/2015: FALSO

ITNERANTE/2015: FALSO

Seção 6 - Planejamento

- ✔ 6.1 Ações para contemplar (*address*) riscos e oportunidades
 - 6.1.1 Geral
 - 6.1.2 Avaliação de riscos de segurança da informação
 - 6.1.3 Tratamento de riscos de segurança da informação.
- ✔ 6.2 Objetivo de segurança da informação e planos para alcançá-los

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.1 Geral

Quando do planejamento do SGSI, a organização deve considerar as questões referenciadas em 4.1 e os requisitos descritos em 4.2 e **determinar os riscos e oportunidades** que precisam ser consideradas para:

- a) assegurar que o SGSI pode alcançar seus resultados;
- b) prevenir ou reduzir os efeitos indesejados;
- c) alcançar a melhoria contínua.

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.1 Geral

A organização deve **planejar**:

- a) as ações para considerar riscos e oportunidades; e
- b) como:
 - 1) integrar e implementar estas ações dentro dos processos do seu SGSI; e
 - 2) avaliar a eficácia (*effectiveness*) destas ações.

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.2 Avaliação (*assessment*)

A organização deve definir e aplicar um processo de avaliação de riscos de segurança da informação que:

- a) estabeleça e mantenha critérios de aceitação riscos de SI e os critérios para o desempenho das avaliações dos riscos de SI;
- b) assegure que as contínuas avaliações de riscos de segurança da informação produzam resultados comparáveis, válidos e consistentes;

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.2 Avaliação (*assessment*)

A organização deve definir e aplicar um processo de avaliação de riscos de segurança da informação que:

- c) **identifique** os riscos de SI contra a perda de confidencialidade, integridade e disponibilidade da informação dentro do escopo do SGSI e **identifique** os responsáveis dos riscos ;

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.2 Avaliação (*assessment*)

A organização deve definir e aplicar um processo de avaliação de riscos de segurança da informação que:

- d) analise** (*analyses*) os riscos para determinar as suas potenciais consequências, a probabilidade realística da suas ocorrência e determinar os níveis de risco;
- e) avalie** (*evaluates*) os riscos de SI comparando os resultados da análise com os critérios estabelecidos e priorize os riscos analisados para o tratamento do risco.

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.3 Tratamento

A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para:

- a) selecionar, de forma apropriada, as **opções de tratamento** dos riscos de SI;
- b) determinar os controles necessários para implementar as opções de tratamento escolhidas;

NOTA: As organizações podem projetar os controles, conforme requerido, ou identificá-los de qualquer outra fonte.

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.3 Tratamento

A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para:

- c) comparar os controles com os do Anexo A e verificar que nenhum controle necessário tenha sido omitido;

NOTA 1 Os usuários desta Norma são instruídos a utilizar o Anexo A para garantir que nenhum controle necessário foi omitido.

NOTA 2 Os objetivos de controle estão implicitamente incluídos nos controles escolhidos.

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.3 Tratamento

A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para:

- d) elaborar uma **declaração de aplicabilidade** que contenha os controles necessários e a justificativa para inclusões bem como para a exclusões;
- e) preparar um **plano** para tratamento dos riscos;

Seção 6 - Planejamento

6.1 Ações para contemplar (*address*) riscos e oportunidades - 6.1.3 Tratamento

A organização deve definir e aplicar um processo de tratamento dos riscos de segurança da informação para:

- f) obter a **aprovação** dos responsáveis pelos riscos do plano de tratamento dos riscos de SI, e a aceitação dos riscos residuais de segurança da informação.

NOTA O processo de tratamento e a avaliação dos riscos de SI desta norma está alinhado aos princípios e diretrizes gerais definidas na ISO/IEC 31000 (Gestão de Riscos – Princípios e Diretrizes).

Seção 6 - Planejamento

6.2 Objetivo de segurança da informação e planos para alcançá-los

A organização deve estabelecer os objetivos de SI para as funções e níveis relevantes que:

- a) sejam consistentes com a política de segurança;
- b) sejam mensuráveis (quando aplicável);
- c) levem em conta os requisitos de segurança da informação aplicáveis, e os resultados da avaliação e tratamento dos riscos;

Seção 6 - Planejamento

6.2 Objetivo de segurança da informação e planos para alcançá-los

A organização deve estabelecer os objetivos de SI para as funções e níveis relevantes que:

- d) sejam comunicados; e
- e) sejam atualizados, conforme apropriado;

A organização deve reter informação documentada dos objetivos de segurança da informação e do processo de avaliação e tratamento dos riscos.

Seção 6 - Planejamento

6.2 Objetivo de segurança da informação e planos para alcançá-los

Quando do planejamento para alcançar os seus objetivos de SI, a organização deve determinar:

- f) o que** será feito;
- g) quais recursos** serão necessários;
- h) quem** será responsável;
- i) quando** estará concluído;
- j) como** os resultados serão avaliados.

QUESTÕES

UNIRIO/2014 - UNIRIO - Analista TI - Segurança da Informação

Com relação a recomendações para o planejamento e a operação de um SGSI, as normas 27001, 27002 e 27005 contêm, respectivamente,

a) um modelo de requisitos para estabelecer, operar, monitorar e melhorar um SGSI; recomendações de boas práticas para a implementação e a manutenção de um SGSI; e recomendações com foco em gerenciamento de risco para implementação e melhoria dos controles citados na ISO 27001.

b) recomendações para o planejamento e a implementação de um SGSI; recomendações para a operação e monitoramento de um SGSI; recomendações para melhorias dos controles citados na ISO 27002 com foco em gerenciamento de risco.

QUESTÕES

UNIRIO/2014 - UNIRIO - Analista TI - Segurança da Informação

Com relação a recomendações para o planejamento e a operação de um SGSI, as normas 27001, 27002 e 27005 contêm, respectivamente,

- c) um modelo arquitetural para a construção de um SGSI; recomendações para implementação, operação e monitoramento de um SGSI; recomendações para controle e gerenciamento de risco de um SGSI.
- d) um modelo para gerenciamento de risco e planejamento de um SGSI; recomendações para implementação, operação, manutenção e melhorias de um SGSI; recomendações de boas práticas de controles para um SGSI.
- e) recomendações para estabelecer, operar e monitorar um SGSI; recomendações de boas práticas para melhorias dos controles citados na ISO 27001; recomendações para gerenciamento de riscos de um SGSI.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

A Declaração de Aplicabilidade deve conter a justificativa para a exclusão de qualquer controle do Anexo A, mas não é necessário que ela também contenha a justificativa para a inclusão de controles.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

Os controles da Norma ISO/IEC 27002 são aplicados no contexto do tratamento dos riscos de segurança da informação identificados através do processo de avaliação dos riscos da Norma ISO/IEC 27001.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

Quanto aos controles estabelecidos no Anexo A da Norma ISO/IEC 27001, as organizações podem utilizá-los ou projetar seus próprios controles, conforme requerido, ou até mesmo identificá-los a partir de qualquer outra fonte.

QUESTÕES

CETAP/2015 - MPCM - Analista de Sistemas - Suporte

Segundo a norma NBR ISO/IEC 27001:2013, os objetivos de segurança de informação devem ser:

- a) consistentes com a política de segurança da informação, mensuráveis, comunicados e atualizados, conforme apropriado.
- b) consistentes com a política de desenvolvimento, atingíveis, comunicados e atualizados, conforme apropriado.
- c) consistentes com a política de segurança da informação, atingíveis, atualizados conforme apropriado e priorizados.
- d) consistentes com o plano de custos, mensuráveis e aprovados pelo conselho diretor.
- e) atuais, mensuráveis, atingíveis, comunicados e atualizados, conforme apropriado.

QUESTÕES

FCC/2015 - TRT - 4ª Região - Analista Judiciário – TI

Considere que um Analista do Tribunal Regional do Trabalho ficou com a tarefa de definir um processo de tratamento dos riscos de segurança da informação de acordo com a Norma NBR ISO/IEC 27001:2013. Uma ação correta é:

- a) Selecionar, de forma apropriada, as opções de tratamento dos riscos de segurança da informação, levando em consideração os resultados da avaliação do risco.
- b) Determinar quais os controles e objetivos de controle definidos pela Norma serão utilizados, sem a inclusão de controles adicionais não listados, como recomendado.
- c) Elaborar, cautelosamente, uma declaração de aplicabilidade que contenha os controles necessários e sua justificativa, já que a Norma recomenda que não haja exclusão de controles.

QUESTÕES

FCC/2015 - TRT - 4ª Região - Analista Judiciário – TI

Considere que um Analista do Tribunal Regional do Trabalho ficou com a tarefa de definir um processo de tratamento dos riscos de segurança da informação de acordo com a Norma NBR ISO/IEC 27001:2013. Uma ação correta é:

- d) Preparar um plano para tratamento dos riscos residuais de segurança da informação, obtendo a aprovação da alta gerência e dos técnicos de TI.
- e) Não reter a informação documentada relativa ao processo de tratamento dos riscos de segurança da informação no Tribunal, já que a Norma recomenda que este documento possa ser ajustado pelos stakeholders e seja público.

QUESTÕES

FCC/2015 - TRT - 15ª Região - Analista Judiciário - TI

Segundo a norma ISO 27001 de 2006, a Segurança da Informação é um conjunto de medidas que visam proteger e preservar informações e sistemas de informações, assegurando-lhes algumas qualidades, EXCETO a

- a) autenticidade.
- b) disponibilidade.
- c) irretratabilidade.
- d) compatibilidade.
- e) integridade.

QUESTÕES - Gabarito

UNIRIO/2014 - UNIRIO: Alternativa A

ITNERANTE/2015: FALSO

ITNERANTE/2015: VERDADEIRO

ITNERANTE/2015: VERDADEIRO

CETAP/2015 - MPCM: Alternativa A

FCC/2015 - TRT - 4ª Região: Alternativa A

FCC/2015 - TRT - 15ª Região: Alternativa D

Seção 7 – Apoio (*Support*)

- ✅ 7.1 Recursos
- ✅ 7.2 Competência
- ✅ 7.3 Conscientização
- ✅ 7.4 Comunicação
- ✅ 7.5 Informação Documentada

Seção 7 – Apoio (*Support*)

7.1 Recursos

A **organização** deve determinar e prover recursos necessários para o estabelecimento, implementação, manutenção e melhoria contínua do SGSI.

Seção 7 – Apoio (*Support*)

7.2 Competência

A organização deve:

- a) determinar a competência necessária das pessoas que realizam trabalho sob o seu controle e que afeta o desempenho da segurança da informação.
- b) assegurar que essas pessoas são competentes com base na educação, treinamento ou experiência.
- c) onde aplicado, tomar ações para adquirir competência e avaliar a eficácia destas ações.

Seção 7 – Apoio (*Support*)

7.2 Competência

A organização deve:

- d) reter informação documentada apropriada como evidência da competência.

NOTA Ações apropriadas podem incluir, por exemplo: fornecimento de treinamento para os facilitadores, os funcionários atuais, ou pessoas competentes, próprias ou contratadas.

Seção 7 – Apoio (*Support*)

7.3 Conscientização

Pessoas que realizam trabalho sob o controle da organização devem estar cientes da:

- a) política de segurança da informação.
- b) suas contribuições para a eficácia do SGSI, incluindo os benefícios da melhoria do desempenho da SI.
- c) implicações da não conformidade com os requisitos do sistema de gestão da segurança da informação.

Seção 7 – Apoio (*Support*)

7.4 Comunicação

A organização deve determinar as comunicações internas e externas relevantes para o SGSI incluindo:

- a) o que comunicar.
- b) quando comunicar.
- c) quem deverá ser comunicado.
- d) quem deverá comunicar.
- e) o processo pelo qual a comunicação será realizada.

Seção 7 – Apoio (*Support*)

7.5 Informação documentada

7.5.1 Geral

O SGSI deve incluir:

- a) informação documentada requerida por esta norma.
- b) informação documentada determinada pela organização como necessária para sua eficácia.

NOTA A abrangência da informação documentada para o SGSI pode variar de uma organização para outra devido a: a) tamanho da organização e tipo de atividades etc.; b) a complexidade dos processos e suas interações; c) a competência das pessoas.

Seção 7 – Apoio (*Support*)

7.5 Informação documentada

7.5.2 Criando e atualizando

Quando da criação e atualização da informação documentada, a organização deve assegurar:

- a) identificação e descrição (título, data, autor ou um número de referência etc.).
- b) formato (linguagem, versão do software, gráficos etc.) e o seu meio (papel, eletrônico etc.).
- c) análise crítica e aprovação para pertinência e adequação.

Seção 7 – Apoio (*Support*)

7.5 Informação documentada

7.5.3 Controle da informação documentada

A informação documentada requerida pelo SGSI e por esta norma, deve ser controlada para assegurar:

- a) que está disponível e adequada para o uso, onde e quando é necessário.
- b) que está adequadamente protegida (contra perda de confidencialidade, uso impróprio ou perda de integridade etc.).

Seção 7 – Apoio (*Support*)

7.5 Informação documentada

7.5.3 Controle da informação documentada

Para o controle da informação documentada, a organização deve considerar as seguintes atividades, conforme aplicada:

- c) distribuição, acesso, recuperação e uso.
- d) armazenagem e preservação, incluindo da legibilidade.
- e) controle de mudanças (controle de versão etc.).
- f) retenção e disposição.

Seção 7 – Apoio (*Support*)

7.5 Informação documentada

7.5.3 Controle da informação documentada

A informação documentada de origem externa, determinada pela organização como necessária para o planejamento e operação do SGSI, deve ser identificada como apropriada, e controlada.

NOTA O acesso implica em uma decisão quanto à permissão para apenas ler a informação documentada, ou a permissão e autoridade para ver e alterar a informação documentada.

Seção 8 – Operação

- ✅ 8.1 Planejamento operacional e controle
- ✅ 8.2 Avaliação de riscos de segurança da informação
- ✅ 8.3 Tratamento de riscos de segurança da informação

Seção 8 – Operação

8.1 Planejamento operacional e controle

A organização deve ¹planejar, implementar e controlar os processos necessários para atender os requisitos de SI, e para implementar as ações determinadas em 6.1.

A organização deve também implementar planos para alcançar os objetivos de SI determinados em 6.2.

A organização deve manter a informação documentada na abrangência necessária para gerar confiança de que os processos estão sendo realizados conforme planejado.

Seção 8 – Operação

8.1 Planejamento operacional e controle

A organização deve controlar as mudanças planejadas e analisar criticamente as consequências de mudanças não previstas, tomando ações para mitigar quaisquer efeitos adversos, conforme necessário.

A organização deve assegurar que os **processos terceirizados** estão determinados e são controlados.

Seção 8 – Operação

8.2 Avaliação de riscos de segurança da informação

A organização deve **realizar avaliações de riscos** de SI a intervalos planejados, quando **mudanças significativas** são propostas ou ocorrem, levando em conta os critérios estabelecidos em 6.1.2 a.

A organização deve reter informação documentada dos resultados das avaliações de risco de segurança da informação.

Seção 8 – Operação

8.3 Tratamento de riscos de segurança da informação

A organização deve **implementar o plano de tratamento** de riscos de segurança da informação.

A organização deve reter informação documentada dos resultados do tratamento dos riscos de segurança da informação.

Seção 9 – Avaliação de Desempenho

- ✅ 9.1 Monitoramento, medição, análise e avaliação
- ✅ 9.2 Auditoria interna
- ✅ 9.3 Análise crítica pela direção

Seção 9 – Avaliação de Desempenho

9.1 Monitoramento, medição, análise e avaliação

A organização deve avaliar o desempenho da SI e a eficácia do SGSI e determinar:

- a) o **que** precisa ser monitorado e medido, incluindo controles e processos de segurança da informação.
- b) os métodos para **monitoramento, medição, análise e avaliação** para assegurar resultados válidos.

NOTA Os métodos selecionados devem produzir resultados comparáveis e reproduzíveis para serem válidos.

Seção 9 – Avaliação de Desempenho

9.1 Monitoramento, medição, análise e avaliação

A organização deve avaliar o desempenho da SI e a eficácia do SGSI e determinar:

- e) **quando** o monitoramento e a medição devem ser realizados e d) **quem** deve monitorar e medir.
- f) **quando** os resultados do monitoramento e da medição devem ser analisados e avaliados e g) **quem** deve analisar e avaliar estes resultados.

A organização deve reter informação documentada apropriada como evidência do monitoramento e dos resultados da medição.

Seção 9 – Avaliação de Desempenho

9.2 Auditoria interna

A organização deve conduzir auditorias internas a intervalos planejados para prover informações sobre o quanto o SGSI:

- a) está em conformidade com:
 - 1) os requisitos da organização para o SGSI;
 - 2) os requisitos desta Norma.
- b) está efetivamente implementado e mantido.

Seção 9 – Avaliação de Desempenho

9.2 Auditoria interna

A organização deve:

- c) planejar, estabelecer, implementar e manter um **programa de auditoria** (frequência, métodos, responsabilidades, requisitos de planejamento e relatórios) que leve em conta a importância dos processos pertinentes e as **auditorias anteriores**.
- d) definir os critérios e o escopo da auditoria, para cada auditoria.

Seção 9 – Avaliação de Desempenho

9.2 Auditoria interna

Organização deve:

- e) selecionar auditores e conduzir auditorias que assegurem **objetividade** e **imparcialidade** do processo de auditoria.
- f) assegurar que os resultados das auditorias são **relatados para a direção pertinente**.
- g) Reter a **informação documentada** como evidência dos programas da auditoria e dos seus resultados.

Seção 9 – Avaliação de Desempenho

9.3 Análise crítica pela direção

A Alta Direção deve analisar criticamente o SGSI a intervalos planejados para assegurar a sua **contínua adequação, pertinência e eficácia** considerando:

- a) situação das ações de análises críticas anteriores, realizadas pela direção.
- b) mudanças nas questões internas e externas, que sejam relevantes para o SGSI.

Seção 9 – Avaliação de Desempenho

9.3 Análise crítica pela direção

A Alta Direção deve analisar criticamente o SGSI a intervalos planejados para assegurar a sua **contínua adequação, pertinência e eficácia** considerando:

- c) realimentação sobre o desempenho da segurança da informação, incluindo tendências nas:
 - 1) não conformidades e ações corretivas;
 - 2) monitoramento e resultados da medição;
 - 3) resultados de auditorias; e
 - 4) cumprimento dos objetivos de SI.

Seção 9 – Avaliação de Desempenho

9.3 Análise crítica pela direção

A Alta Direção deve analisar criticamente o SGSI a intervalos planejados para assegurar a sua **contínua adequação, pertinência e eficácia** considerando:

- d) realimentação** das partes interessadas.
- e) resultados da avaliação dos riscos** e situação do plano de **tratamento dos riscos**.
- f) oportunidades** para melhoria contínua.

Seção 9 – Avaliação de Desempenho

9.3 Análise crítica pela direção

Os resultados da análise crítica pela Direção devem incluir **decisões** relativas a oportunidades de melhoria e quaisquer necessidades para mudanças do SGSI.

A organização deve reter informação documentada como evidência dos resultados das análises críticas pela direção.

Seção 10 – Melhoria

- ✅ 10.1 Não conformidade e ação corretiva
- ✅ 10.2 Melhoria contínua

Seção 10 – Melhoria

10.1 Não conformidade e ação corretiva

Em caso de não conformidade, a organização deve:

- a) reagir e conforme apropriado:
 - 1) tomar ações para controlar e corrigi-la; e
 - 2) tratar com as consequências;
- b) avaliar a necessidade de ações para eliminar as causas e evitar sua repetição ou ocorrência:
 - 1) analisando criticamente a não conformidade;
 - 2) determinando as causas da não conformidade; e
 - 3) determinando se não conformidades similares existem, ou podem potencialmente ocorrer.

Seção 10 – Melhoria

10.1 Não conformidade e ação corretiva

Em caso de não conformidade, a organização deve:

- c) implementar quaisquer ações necessárias;
- d) analisar criticamente a eficácia de quaisquer ações corretivas tomadas; e
- e) realizar mudanças no SGSI, quando necessário.

As ações corretivas devem ser apropriadas aos efeitos das não conformidades encontradas.

Seção 10 – Melhoria

10.1 Não conformidade e ação corretiva

A organização deve reter informação documentada como evidência da:

- f) natureza das não conformidades e quaisquer ações subsequentes tomadas; e
- g) resultados de qualquer ação corretiva.

Seção 10 – Melhoria

10.2 Melhoria contínua

A organização deve continuamente melhorar a pertinência, adequação e eficácia do SGSI.

QUESTÕES

CESPE/2015 - STJ - Analista Judiciário - Suporte em TI

Com base nas normas ISO 27001, ISO 27002, ISO 27003, ISO 27004 e ISO 27005, relativas à segurança de ativos de informação das organizações, julgue o item a seguir.

De acordo com a norma ISO 27001, o sistema de gerenciamento da segurança da informação deve ser revisado regularmente, considerando-se as sugestões e os feedbacks das partes interessadas.

QUESTÕES

CESPE/2014 - TJ-SE - Analista Judiciário - Suporte em Infraestrutura

Com base no disposto nas normas NBR ISO/IEC 27001 e 27002 e na ITIL (versão 3), julgue os itens seguintes.

O sistema de gestão de segurança da informação inclui estrutura, políticas, atividades de planejamento, práticas, procedimentos, recursos e processos da organização.

QUESTÕES

CESPE/2014 - TJ-SE - Analista Judiciário - Suporte em Infraestrutura

Com base no disposto nas normas NBR ISO/IEC 27001 e 27002 e na ITIL (versão 3), julgue os itens seguintes

A política de segurança da informação, os objetivos e as atividades que refletem os objetivos do negócio são fatores críticos de sucesso na implementação da segurança da informação em uma organização.

QUESTÕES

VUNESP/2014 - TJ-PA - Analista Judiciário - Análise de Sistema

A norma ISO 27001 estabelece requisitos para a documentação, visando o sistema de gestão de segurança da informação. Sobre essa documentação, é correto afirmar que

- a) deve conter procedimentos e controles de apoio ao sistema de gerenciamento da segurança da informação.
- b) não contempla um relatório de análise de riscos do sistema de gerenciamento da segurança da informação.
- c) não inclui uma descrição do escopo do sistema de gerenciamento da segurança da informação.
- d) não contempla um plano de tratamento de riscos do sistema de gerenciamento da segurança da informação.
- e) deve contemplar a listagem completa dos programas fonte inseridos no sistema de gerenciamento da segurança da informação.

QUESTÕES

ITNERANTE/2015

Com base na família de normas ISO/IEC 27000, julgue o item abaixo:

A seção da Norma ISO 27001 que trata do Apoio da organização ao SGSI tem como requisito a determinação de quais são as competências necessárias das partes interessadas que realizam trabalho que possa afetar a segurança da informação.

QUESTÕES

TIMASTERS/2015

A declaração de aplicabilidade deve ser elaborada:

- a) Na avaliação do Contexto da Organização.
- b) Na Identificação dos requisitos das partes interessadas.
- c) Na Análise dos riscos e oportunidades
- d) No Tratamento dos riscos e oportunidades
- e) Na Melhoria Contínua do SGSI.

QUESTÕES

CETAP/2015 - MPCM - Analista de Sistemas - Suporte

Segundo a norma NBR ISO/IEC 27001:2013, no que se refere ao monitoramento da eficácia do SGSI, a organização deve determinar os seguintes elementos, exceto:

- a) O que precisa ser monitorado e medido.
- b) Quando o monitoramento e medição devem ser realizados.
- c) Quando os resultados do monitoramento e da medição devem ser analisados e avaliados.
- d) Quem deve analisar e avaliar estes resultados.
- e) Quanto deve custar o monitoramento e medição.

QUESTÕES - Gabarito

CESPE/2015 - STJ: CERTO

CESPE/2014 - TJ-SE: CERTO

CESPE/2014 - TJ-SE: CERTO

VUNESP/2014 - TJ-PA: Alternativa A

ITNERANTE/2015: FALSO

TIMASTERS/2015: Alternativa D

CETAP/2015 - MPCM: Alternativa E